

LatticePay – Compliance, Risk & AI Governance Workbook

Overview

This workbook is a comprehensive GRC and AI governance portfolio artifact built for a fictional fintech organization, LatticePay. It demonstrates how I design and operationalize an integrated governance framework across:

- Information Security (ISO 27001)
- AI Governance (ISO 42001)
- Cybersecurity (NIST CSF)
- Risk Management
- Control Design
- Certification Readiness
- AI System Lifecycle Oversight

The workbook models how a modern fintech would prepare for ISO 27001 certification, ISO 42001 readiness, and enterprise-grade risk governance.

Scope

ISMS Scope (ISO 27001)

The Information Security Management System (ISMS) covers:

- Cloud infrastructure (Azure, AWS)
- Cloudflare security services
- CRM and customer data systems
- Corporate devices
- Email & collaboration tools
- Website & customer portal
- Backup & recovery systems

- Network firewalls & security appliances
- Physical access controls

AIMS Scope (ISO 42001)

The AI Management System (AIMS) covers:

- AI-001 Fraud Scoring Model
- AI-002 Underwriting Assistant
- AI-003 Customer Support Copilot
- AI-004 Engineering Copilot

Only AI systems and AI-specific governance processes are included in the AIMS scope.

Workbook Structure

1. Asset Inventory

A complete inventory of LatticePay's information assets with:

- Classification
- Ownership
- Legal requirements
- Retention
- ISO 27001 mappings
- NIST CSF mappings

2. Risk Mapping

Threats, vulnerabilities, and control mappings for each asset, aligned to:

- ISO 27001 Annex A
- NIST CSF
- Control Library (CL-00X)

3. Heat Map & Dashboard

Quantitative scoring of inherent and residual risk, visualized for governance reporting.

4. Control Library

A unified library of ISMS and AIMS controls with:

- Control IDs (CL-000 to CL-007)
- ISO 27001 mappings

ISO 42001 mappings (AI controls only)

Evidence requirements

Maturity scoring

5. Certification Readiness Tracker

Clause-level readiness for ISO 27001 and ISO 42001, including:

- Evidence
- Owners
- Status
- Notes

6. AI System Inventory

Lifecycle-aligned inventory of all AI systems with:

- Risk level
- Oversight model (HITL/HOTL)
- Monitoring
- Evidence
- Ownership

7. Risk Treatment Plan

Explicit linkage between:

- Risks
- Treatment actions
- Control IDs
- Owners
- Residual risk targets

How to Use This Workbook

1. Start with the Asset Inventory to understand the environment.
2. Review Risk Mapping to see how threats and vulnerabilities are mitigated.
3. Use the Heat Map for governance and prioritization.
4. Consult the Control Library for evidence and maturity.
5. Check Certification Readiness to understand compliance posture.
6. Review the AI System Inventory for AI governance alignment.
7. Use the Risk Treatment Plan to track remediation progress.

Version History

Version	Date	Summary
1.0	April 2026	Initial release with full ISMS + AIMS integration

Author

Rani Rookwood

Portfolio Demonstration – Fictional Scenario for LatticePay